

João Paulo Garcia, João Pedro Magalhães, Miguel Luis Schwengber

# **Aplicação de Protocolos de Oblivious Transfer para Preservação de Privacidade em Transações Digitais**

São Paulo, SP

2026

João Paulo Garcia, João Pedro Magalhães, Miguel Luis Schwengber

## **Aplicação de Protocolos de Oblivious Transfer para Preservação de Privacidade em Transações Digitais**

Trabalho de conclusão de curso apresentado ao Departamento de Engenharia de Computação e Sistemas Digitais da Escola Politécnica da Universidade de São Paulo para obtenção do Título de Engenheiro.

Universidade de São Paulo – USP

Escola Politécnica

Departamento de Engenharia de Computação e Sistemas Digitais (PCS)

Orientador: Prof. Dr. Thales Areco Bandiera Paiva

São Paulo, SP

2026

# Sumário

|            |                                              |           |
|------------|----------------------------------------------|-----------|
| <b>1</b>   | <b>INTRODUÇÃO</b>                            | <b>4</b>  |
| <b>1.1</b> | <b>Motivação</b>                             | <b>4</b>  |
| <b>1.2</b> | <b>Objetivos</b>                             | <b>4</b>  |
| <b>1.3</b> | <b>Justificativa</b>                         | <b>5</b>  |
| <b>1.4</b> | <b>Organização do Trabalho</b>               | <b>5</b>  |
| <b>2</b>   | <b>ASPECTOS CONCEITUAIS</b>                  | <b>6</b>  |
| <b>2.1</b> | <b>Oblivious Transfer (OT)</b>               | <b>6</b>  |
| 2.1.1      | Definição                                    | 6         |
| <b>2.2</b> | <b>Variantes de OT</b>                       | <b>6</b>  |
| 2.2.1      | 1-out-of-2 OT                                | 6         |
| 2.2.2      | 1-out-of-n OT                                | 7         |
| 2.2.3      | k-out-of-n OT                                | 7         |
| 2.2.4      | Generalized Oblivious Transfer (GOT)         | 7         |
| 2.2.5      | Definição                                    | 7         |
| 2.2.6      | Funcionalidade                               | 8         |
| 2.2.7      | Relação com OT Clássico                      | 8         |
| 2.2.8      | Interpretação                                | 8         |
| 2.2.9      | Implementação                                | 8         |
| <b>2.3</b> | <b>OT Extension</b>                          | <b>8</b>  |
| <b>2.4</b> | <b>Criptossistema de Rabin</b>               | <b>9</b>  |
| 2.4.1      | Definição                                    | 9         |
| <b>3</b>   | <b>MÉTODO DO TRABALHO</b>                    | <b>11</b> |
| <b>3.1</b> | <b>Visão Geral do Processo</b>               | <b>11</b> |
| <b>3.2</b> | <b>Fase 1 — Fundamentação Teórica</b>        | <b>11</b> |
| <b>3.3</b> | <b>Fase 2 — Especificação de Requisitos</b>  | <b>11</b> |
| <b>3.4</b> | <b>Fase 3 — Projeto da Solução</b>           | <b>11</b> |
| <b>3.5</b> | <b>Fase 4 — Implementação Incremental</b>    | <b>12</b> |
| <b>3.6</b> | <b>Fase 5 — Testes e Avaliação</b>           | <b>12</b> |
| <b>3.7</b> | <b>Fase 6 — Consolidação e Análise Final</b> | <b>12</b> |
| <b>4</b>   | <b>ESPECIFICAÇÃO DE REQUISITOS E SISTEMA</b> | <b>13</b> |
| <b>4.1</b> | <b>Requisitos Funcionais</b>                 | <b>13</b> |
| <b>4.2</b> | <b>Requisitos Não Funcionais</b>             | <b>15</b> |
| <b>4.3</b> | <b>Modelo de Ameaça</b>                      | <b>15</b> |

|     |                                            |    |
|-----|--------------------------------------------|----|
| 4.4 | Projeto Proposto . . . . .                 | 16 |
| 4.5 | Casos de uso e diagrama de fluxo . . . . . | 17 |
|     | REFERÊNCIAS . . . . .                      | 20 |

# 1 Introdução

Este documento apresenta o projeto de formatura intitulado “Aplicação de Protocolos de Oblivious Transfer para Preservação de Privacidade em Transações Digitais”.

## 1.1 Motivação

No cenário atual do comércio eletrônico, a coleta massiva de dados se tornou uma prática recorrente, de forma que qualquer compra torna a navegação pela internet uma experiência infestada de anúncios de produtos relacionados. Embora a vantagem de marketing dessa prática seja inegável, fornecer para os consumidores a privacidade que a maioria das lojas virtuais atualmente viola é um aspecto de grande interesse e necessidade para a sociedade.

## 1.2 Objetivos

**Objetivo Geral:** Desenvolver um protótipo funcional de um sistema de venda de ativos digitais em formato de catálogo, utilizando criptografia baseada em Oblivious Transfer (Transferência Inconsciente) para passar chaves de criptografia simétrica usadas para descriptografar os bens digitais adquiridos de Rede de Distribuição de Conteúdo (Content Delivery Network – CDN), garantindo que o servidor da loja seja incapaz de identificar quais produtos foram acessados ou adquiridos por um comprador específico.

### **Objetivos Específicos:**

- Modelar a arquitetura do sistema para permitir a transação segura onde a escolha do cliente é ofuscada para o servidor.
- Implementar o algoritmo criptográfico escolhido (como 1-out-of-N) em uma solução com 3 componentes: site online, rede de distribuição de conteúdo (CDN) e executável local offline.
- Desenvolver mecanismos para validar a legitimidade da transação sem revelar o conteúdo da compra.
- Realizar testes de segurança e desempenho para validar a impossibilidade de rastreamento de preferências.

### 1.3 Justificativa

O projeto propõe uma solução técnica para um problema crescente de privacidade digital. O sistema permitirá que o comprador adquira produtos digitais dentre várias opções, tendo acesso a apenas uma, mas de forma que o vendedor permaneça matematicamente incapaz de saber qual item específico foi selecionado pelo cliente.

A metodologia envolverá a implementação de algoritmos de Oblivious Transfer integrados a uma interface de venda, garantindo que a loja receba o pagamento, mas não consiga registrar históricos de compras, preferências ou interesses do usuário, assegurando assim um elevado nível de privacidade para os consumidores.

### 1.4 Organização do Trabalho

Este documento está estruturado da seguinte forma: o Capítulo 2 apresenta os conceitos fundamentais que embasam este projeto. O Capítulo 3 descreve a metodologia do trabalho. O Capítulo 4 detalha a especificação de requisitos do sistema. O Capítulo 5 expõe o desenvolvimento e a implementação da solução. Por fim, o Capítulo 6 reúne as considerações finais do estudo.

## 2 Aspectos Conceituais

### 2.1 Oblivious Transfer (OT)

#### 2.1.1 Definição

Oblivious Transfer (OT) é um protocolo criptográfico entre duas partes:

- *Sender*  $S$ , que possui um conjunto de mensagens  $X = \{x_0, x_1, \dots, x_{n-1}\}$ ;
- *Receiver*  $R$ , que escolhe um índice  $i \in \{0, \dots, n-1\}$ .

O protocolo garante que:

1.  $R$  aprende apenas  $x_i$ ;
2.  $R$  não aprende nenhuma informação sobre  $x_j$  para  $j \neq i$ ;
3.  $S$  não aprende qual índice  $i$  foi escolhido.

Formalmente, o objetivo é realizar:

$$(x_0, \dots, x_{n-1}), i \longrightarrow x_i$$

sem violar as propriedades de privacidade.

### 2.2 Variantes de OT

#### 2.2.1 1-out-of-2 OT

O caso mais simples ocorre quando o *sender* possui duas mensagens:

$$(x_0, x_1)$$

O *receiver* escolhe um bit:

$$r \in \{0, 1\}$$

Ao final do protocolo, o *receiver* obtém:

$$x_r$$

sem aprender  $x_{1-r}$ , e o *sender* não descobre o valor de  $r$ .

### 2.2.2 1-out-of-n OT

Generalização do caso anterior:

- *Sender* possui  $n$  mensagens;
- *Receiver* escolhe um índice  $i \in \{0, \dots, n-1\}$ ;

O *receiver* obtém apenas  $x_i$ , mantendo as mesmas garantias de privacidade.

### 2.2.3 k-out-of-n OT

Nesta variante:

- *Sender* possui  $n$  mensagens;
- *Receiver* escolhe um subconjunto  $I \subseteq \{0, \dots, n-1\}$  tal que  $|I| = k$ .

O *receiver* aprende:

$$\{x_i : i \in I\}$$

sem obter informação sobre as demais mensagens.

### 2.2.4 Generalized Oblivious Transfer (GOT)

O Generalized Oblivious Transfer (GOT) é uma generalização do Oblivious Transfer tradicional, introduzida por Ishai e Kushilevitz. (TASSA, 2011)

### 2.2.5 Definição

Seja Alice portadora de um conjunto de mensagens

$$M = \{M_1, M_2, \dots, M_n\}.$$

Seja  $[n] = \{1, 2, \dots, n\}$  o conjunto de índices.

Define-se uma coleção  $\mathcal{A} \subseteq 2^{[n]}$  de subconjuntos permitidos, chamada de coleção monotônica decrescente, isto é,

$$S \in \mathcal{A} \text{ e } S' \subseteq S \implies S' \in \mathcal{A}.$$

### 2.2.6 Funcionalidade

Bob escolhe um subconjunto  $S \subseteq [n]$  tal que  $S \in \mathcal{A}$ . Ao final do protocolo:

- Bob aprende exatamente as mensagens  $\{M_i\}_{i \in S}$ ;
- Bob não aprende nenhuma informação sobre  $\{M_i\}_{i \notin S}$ ;
- Alice não aprende nenhuma informação sobre o subconjunto  $S$  escolhido por Bob.

### 2.2.7 Relação com OT Clássico

- No 1-out-of- $n$  OT:

$$\mathcal{A} = \{S \subseteq [n] \mid |S| = 1\}.$$

- No  $k$ -out-of- $n$  OT:

$$\mathcal{A} = \{S \subseteq [n] \mid |S| = k\}.$$

- No GOT:

$$\mathcal{A} \subseteq 2^{[n]}$$

pode ser qualquer coleção monotônica decrescente.

### 2.2.8 Interpretação

O GOT permite especificar políticas arbitrárias de acesso, desde que sejam fechadas por inclusão (monotonicidade decrescente). Por exemplo:

- todos os subconjuntos de tamanho  $\leq k$ ;
- qualquer subconjunto que não contenha simultaneamente dois índices específicos;
- qualquer subconjunto contido em um conjunto autorizado  $T$ .

### 2.2.9 Implementação

Ishai e Kushilevitz mostraram que o GOT pode ser implementado a partir de múltiplas execuções paralelas de protocolos 1-out-of-2 OT.

## 2.3 OT Extension

Executar muitos OTs base (baseados em criptografia de chave pública) é computacionalmente custoso.

A técnica de OT Extension permite:

1. Executar um pequeno número de OTs base;
2. Expandir para milhares ou milhões de OTs usando apenas criptografia simétrica.

Isso reduz drasticamente o custo computacional, tornando MPC prático.

## 2.4 Criptossistema de Rabin

O criptossistema de Rabin é uma família de esquemas de criptografia de chave pública baseada em uma função armadilha cuja segurança, assim como a do RSA, está relacionada à dificuldade da fatoração de inteiros.

A função armadilha de Rabin tem a vantagem de que inverter essa função foi matematicamente provado ser tão difícil quanto fatorar inteiros, enquanto não há prova semelhante conhecida para a função armadilha do RSA. Ela tem a desvantagem de que cada saída da função de Rabin pode ser gerada por qualquer uma de quatro entradas possíveis; se cada saída for um texto cifrado, é necessária complexidade adicional na decifração para identificar qual das quatro entradas possíveis era o texto plano verdadeiro. Tentativas ingênuas de contornar esse problema frequentemente possibilitam um ataque de texto cifrado escolhido para recuperar a chave secreta ou, ao codificar redundância no espaço do texto plano, invalidam a prova de segurança em relação à fatoração.

Esquemas de criptografia de chave pública baseados na função armadilha de Rabin são usados principalmente como exemplos em livros-texto. Em contraste, o RSA é a base de esquemas padrão de criptografia de chave pública, como o RSAES-PKCS1-v1\_5 e o RSAES-OAEP, que são amplamente utilizados na prática. (RABIN, 2005)

### 2.4.1 Definição

Sejam  $p$  e  $q$  primos grandes, escolhidos de forma que

$$p \equiv q \equiv 3 \pmod{4},$$

e:

$$n = p \cdot q$$

Uma mensagem  $M$  é convertida em um número:

$$m < n$$

A encriptação é definida como:

$$c = m^2 \bmod n$$

O *ciphertext* é  $c$ .

A mensagem  $m$  pode ser recuperada a partir do texto cifrado  $c$  calculando sua raiz quadrada módulo  $n$ , como segue.

Calcule a raiz quadrada de  $c$  módulo  $p$  e módulo  $q$  utilizando as seguintes fórmulas:

$$m_p = c^{\frac{1}{4}(p+1)} \bmod p$$

$$m_q = c^{\frac{1}{4}(q+1)} \bmod q$$

Essas fórmulas só são válidas porque  $p \equiv q \equiv 3 \pmod{4}$ : nesse caso  $\frac{1}{4}(p+1)$  e  $\frac{1}{4}(q+1)$  são inteiros e, pelo critério de Euler,  $m_p^2 \equiv c \pmod{p}$  e  $m_q^2 \equiv c \pmod{q}$ . Por isso a geração de chaves deve impor essa condição.

Utilize o algoritmo de Euclides estendido para encontrar  $y_p$  e  $y_q$  tais que:

$$y_p \cdot p + y_q \cdot q = 1.$$

Aplique o Teorema Chinês do Resto para encontrar as quatro raízes quadradas de  $c$  módulo  $n$ :

$$r_1 = (y_p \cdot p \cdot m_q + y_q \cdot q \cdot m_p) \bmod n$$

$$r_2 = n - r_1$$

$$r_3 = (y_p \cdot p \cdot m_q - y_q \cdot q \cdot m_p) \bmod n$$

$$r_4 = n - r_3$$

Um desses quatro valores é o texto plano original  $m$ , embora não seja possível determinar qual deles é o correto sem informação adicional.

## 3 Método do Trabalho

Este capítulo descreve o processo adotado para desenvolver o projeto, cujo objetivo é implementar um protótipo de livraria digital com preservação de privacidade por meio de Oblivious Transfer (OT). O método foi estruturado em fases de forma a manter alinhamento com os objetivos definidos no Capítulo 1.

### 3.1 Visão Geral do Processo

O processo de desenvolvimento foi organizado em seis fases principais: fundamentação teórica, especificação de requisitos, projeto da solução, implementação do protótipo, testes e avaliação, e consolidação dos resultados.

### 3.2 Fase 1 — Fundamentação Teórica

Na primeira fase, foram estudados os conceitos criptográficos necessários para o projeto, com ênfase em OT e suas variantes (como 1-out-of-n e GOT), além de técnicas relacionadas, como OT Extension e fundamentos do criptossistema de Rabin. Essa etapa forneceu base para as decisões arquiteturais e para a definição dos limites de segurança do protótipo (RABIN, 2005; TASSA, 2011).

### 3.3 Fase 2 — Especificação de Requisitos

Com base nos objetivos do trabalho, foi conduzida a elicitação e organização dos requisitos funcionais e não funcionais do sistema. Essa fase formaliza o que a solução deve fazer e quais restrições de desempenho, segurança e usabilidade devem ser atendidas. O detalhamento dessa etapa é apresentado no Capítulo 4.

### 3.4 Fase 3 — Projeto da Solução

Após a definição dos requisitos, pretende-se fazer o projeto com uma arquitetura inicial de referência. Os objetivos iniciais do projeto são: organização em três componentes (sistema web, CDN e executável local), modelagem preliminar do fluxo de compra privada, alternativas de agrupamento de itens por faixa de preço e possíveis formatos de artefatos de criptografia enviados. Nessa etapa, os critérios de separação entre operações online e descryptografia offline serão definidos conforme os resultados parciais. O detalhamento dessa etapa é apresentado no Capítulo 5.

### 3.5 Fase 4 — Implementação Incremental

A implementação deve ser conduzida em incrementos. A sequência abaixo representa uma proposta inicial, passível de ajustes durante o desenvolvimento:

- estrutura de catálogo e cadastro de itens;
- fluxo de compra com coleta mínima de dados do cliente;
- execução do mecanismo criptográfico associado à escolha privada;
- emissão de tokens com assinatura cega e entrega do conteúdo cifrado pela CDN;
- suporte ao processo de recuperação local dos itens adquiridos.

Esse encadeamento foi definido como estratégia de partida e poderá ser reordenado caso surjam problemas técnicos ou necessidades de validação não previstas. O detalhamento dessa etapa é apresentado no Capítulo 5.

### 3.6 Fase 5 — Testes e Avaliação

Na fase de avaliação, pretende-se priorizar três questões: (i) eficácia do sistema, com foco no atendimento aos requisitos; (ii) nível de privacidade, buscando provas de que o servidor não infere a escolha específica do cliente; e (iii) desempenho, com medições de tempo de busca, compra e entrega. Os procedimentos exatos de teste e o recorte final de métricas serão definidos ao longo da implementação e posteriormente descritos no Capítulo 5.

### 3.7 Fase 6 — Consolidação e Análise Final

Na etapa final, pretende-se consolidar os resultados alcançados e analisá-los com os objetivos do projeto, dando ênfase nas limitações observadas, contribuições efetivas e possibilidades de continuidade. O nível de profundidade dessa análise dependerá do que for possível concluir nas etapas anteriores e será apresentado no Capítulo 6.

## 4 Especificação de Requisitos e Sistema

Este capítulo apresenta os requisitos da solução proposta para uma livraria digital em modelo de catálogo, que utiliza um algoritmo *oblivious* para viabilizar a venda dos itens mantendo a privacidade sobre qual item foi comprado.

### 4.1 Requisitos Funcionais

- **RF01 — Cadastro de administradores:** o sistema deve permitir o cadastro, autenticação e gerenciamento de perfis de administradores.
- **RF02 — Manuseio de livros no catálogo:** o sistema deve permitir ao administrador cadastrar, editar, consultar e remover livros do catálogo.
- **RF03 — Política de preços discretos:** o sistema deve permitir a precificação de cada livro dentro de um conjunto de preços pré-definidos.
- **RF04 — Busca e navegação no catálogo:** o sistema deve permitir que clientes pesquisem livros por critérios como título, autor, categoria e preço.
- **RF05 — Compra sem cadastro de cliente:** o sistema deve permitir compra sem criação de conta de cliente.
- **RF06 — E-mail obrigatório na compra:** no fluxo de compra, o cliente deve informar um e-mail válido para recebimento da resposta do protocolo de OT, a partir da qual o executável local extrai a chave do produto digital.
- **RF07 — Compra privada de N itens em grupo:** o cliente deve conseguir comprar N livros dentre um grupo maior de livros com o mesmo preço sem que a informação dos itens específicos comprados seja enviada ao servidor em formato que ele consiga decifrar.
- **RF08 — Entrega de material criptográfico para cliente:** o sistema deve fornecer ao cliente os dados necessários (a resposta do protocolo de OT e informações relacionadas) para que as chaves simétricas dos livros escolhidos sejam extraídas em ambiente local. O servidor não conhece as chaves finais obtidas pelo cliente.
- **RF09 — Arquitetura com três componentes:** a solução deve ser composta por (i) um sistema web para catálogo, administração, pagamento, execução do OT e assinatura cega de tokens; (ii) uma CDN, que armazena os livros cifrados e os

entrega mediante token válido; e (iii) um executável local offline, que guarda o estado secreto do cliente e descriptografa os livros.

- **RF10 — Descriptografia local offline:** o cliente deve conseguir descriptografar o item resgatado por meio de um executável local que não se conecta à internet, ao informar o livro cifrado e a resposta do OT recebida.
- **RF11 — Gestão do segredo no executável local:** o executável local deve gerar a requisição de OT e guardar o segredo dessa requisição, necessário para extrair, a partir da resposta do servidor, as chaves criptográficas dos itens adquiridos.
- **RF12 — Não acesso a itens não comprados:** o cliente não deve conseguir descriptografar livros que não tenham sido comprados.
- **RF13 — Processamento de pagamento:** o sistema deve realizar o processamento do pagamento da compra por meio de mecanismo integrado de cobrança (gateway de pagamento) e retornar o status da transação ao cliente.
- **RF14 — Envio da resposta do OT por e-mail:** após a confirmação do pagamento, o sistema deve enviar para o e-mail informado a resposta do OT correspondente à compra. O e-mail não contém a chave do livro, que o servidor desconhece.
- **RF15 — Persistência para reenvio ao cliente:** o sistema deve manter os dados da compra de forma que o cliente possa solicitar o reenvio da resposta do OT para o mesmo e-mail informado originalmente, dentro de um prazo definido pela plataforma.
- **RF16 — Emissão de tokens com assinatura cega:** para cada compra de N itens, o sistema web deve assinar às cegas N valores gerados pelo cliente, resultando em N tokens que autorizam, cada um, o download de um livro na CDN. Os tokens não devem poder ser ligados à sessão de assinatura.
- **RF17 — Entrega de livros pela CDN mediante token:** a CDN deve entregar um livro cifrado apenas mediante a apresentação de um token com assinatura válida e ainda não utilizado.
- **RF18 — Reporte de uso da CDN:** a CDN deve reportar ao sistema web os tokens utilizados e a quantidade de livros entregues, para fins de remuneração. O reporte não deve conter o livro associado a cada token nem horários que permitam correlação com as compras.

## 4.2 Requisitos Não Funcionais

- **RNF01 — Segurança criptográfica:** o mecanismo de proteção deve atingir um nível mínimo de 128 bits de segurança, isto é, um ataque ao mecanismo deve exigir da ordem de  $2^{128}$  operações.
- **RNF02 — Tempo limite de busca:** cada operação de busca no catálogo deve ser concluída em um tempo de resposta limite de 5 segundos.
- **RNF03 — Tempo limite de finalização da compra:** a finalização da compra deve ser concluída em um tempo de resposta limite de 1 minuto.
- **RNF04 — Tempo limite de envio por e-mail:** o sistema deve enviar o e-mail contendo a resposta do OT dentro de um tempo de resposta limite de 1 minuto após confirmação do pagamento.
- **RNF05 — Capacidade de processamento:** a plataforma deve suportar uma quantidade mínima de 600 transações por minuto.
- **RNF06 — Disponibilidade:** a plataforma deve atingir um valor mínimo de 99% de *uptime* por mês.
- **RNF07 — Usabilidade:** o fluxo de compra deve atingir uma taxa mínima de conclusão sem suporte externo igual a 99%.
- **RNF08 — Manutenibilidade:** alterações evolutivas de baixa complexidade devem ser implementadas em um tempo máximo de 8 horas úteis de manutenção.

## 4.3 Modelo de Ameaça

O projeto adota as seguintes premissas de segurança, que orientam as decisões de arquitetura:

- **Site e CDN não são coniventes.** Essa premissa é garantida por auditoria. Com isso, o site sabe *quem* comprou, mas não *o quê*; a CDN sabe *o quê* foi baixado, mas não *quem* comprou. Essa separação de conhecimento é intencional e não constitui uma falha do sistema.
- **O reporte da CDN ao site deve ser mínimo.** Ele contém apenas os tokens utilizados e a quantidade de entregas, nunca o livro associado a cada token nem horários que permitam correlacionar downloads com compras (RF18).

- **Os tokens não podem ser ligados à compra.** A assinatura cega garante que o site, ao receber um token no reporte da CDN, não consiga associá-lo à sessão de assinatura em que foi emitido (RF16).
- **O servidor não conhece a chave final do cliente.** O site executa sua parte do OT sem saber quais chaves o cliente extraiu. Por isso o e-mail (RF14) e o reenvio (RF15) carregam a *resposta do OT*, e não a chave. Somente o executável local, que guarda o segredo da requisição (RF11), consegue extrair a chave.

## 4.4 Projeto Proposto

A partir dos requisitos, a ideia inicial do projeto é uma plataforma de venda de chaves de livros criptografados, que são distribuídos por uma CDN. A solução é composta por três componentes:

1. **Sistema web (site):** catálogo, administração, preços discretos, pagamento via gateway, execução do OT e assinatura cega de tokens. A compra não exige conta; apenas o e-mail é solicitado.
2. **CDN:** armazena os livros cifrados e entrega um livro mediante um token com assinatura cega válido. Posteriormente, reporta ao site os tokens utilizados para ser remunerada.
3. **Executável local offline:** guarda o estado secreto do cliente e descriptografa os livros sem acesso à internet.

No fluxo de compra, o cliente escolhe um grupo de livros de mesmo preço e obtém, por meio do OT, as chaves de  $N$  itens desse grupo, sem que o site saiba quais foram escolhidos. O cliente recebe também  $N$  tokens com assinatura cega, com os quais baixa os livros cifrados na CDN, e em seguida os descriptografa localmente. Como cada download consome um token e a CDN reporta os tokens utilizados, torna-se possível a remuneração justa da CDN sem revelar ao site quais livros foram adquiridos.

## 4.5 Casos de uso e diagrama de fluxo

Tabela 1 – Agentes e Casos de Uso do Sistema

| ID   | Agente                     | Caso de Uso                                                                       |
|------|----------------------------|-----------------------------------------------------------------------------------|
| UC01 | Administrador              | Gerenciar conta de administrador (cadastro, login e edição)                       |
| UC02 | Administrador              | Gerenciar catálogo de livros (cadastrar, editar, consultar e remover)             |
| UC03 | Administrador              | Definir política de preços discretos para os livros                               |
| UC04 | Cliente                    | Buscar e navegar no catálogo de livros                                            |
| UC05 | Cliente                    | Realizar compra sem necessidade de cadastro                                       |
| UC06 | Cliente                    | Informar e-mail válido para recebimento da resposta do OT                         |
| UC07 | Cliente                    | Realizar compra privada de N itens utilizando protocolo <i>oblivious transfer</i> |
| UC08 | Sistema                    | Processar pagamento da compra                                                     |
| UC09 | Sistema                    | Executar o OT e entregar a resposta ao cliente                                    |
| UC10 | Sistema                    | Enviar resposta do OT por e-mail após pagamento                                   |
| UC11 | Cliente                    | Solicitar reenvio da resposta do OT                                               |
| UC12 | Sistema                    | Persistir dados da compra para reenvio                                            |
| UC13 | Sistema                    | Assinar às cegas os N valores do cliente (emissão de tokens)                      |
| UC14 | Cliente                    | Baixar livro cifrado na CDN apresentando um token                                 |
| UC15 | CDN                        | Validar token e entregar livro cifrado                                            |
| UC16 | CDN                        | Reportar tokens utilizados e quantidade ao site                                   |
| UC17 | Sistema                    | Validar tokens reportados e remunerar a CDN                                       |
| UC18 | Cliente (Executável Local) | Descriptografar conteúdo offline                                                  |
| UC19 | Sistema (Executável Local) | Guardar o segredo da requisição e extrair a chave localmente                      |
| UC20 | Sistema                    | Garantir que itens não comprados não possam ser acessados                         |

A Figura 1 apresenta o fluxo da administração do catálogo até a compra, e a Figura 2 apresenta a entrega pela CDN, o reporte de uso e a descriptografia offline.

Figura 1 – Diagrama de sequência: administração, navegação e compra

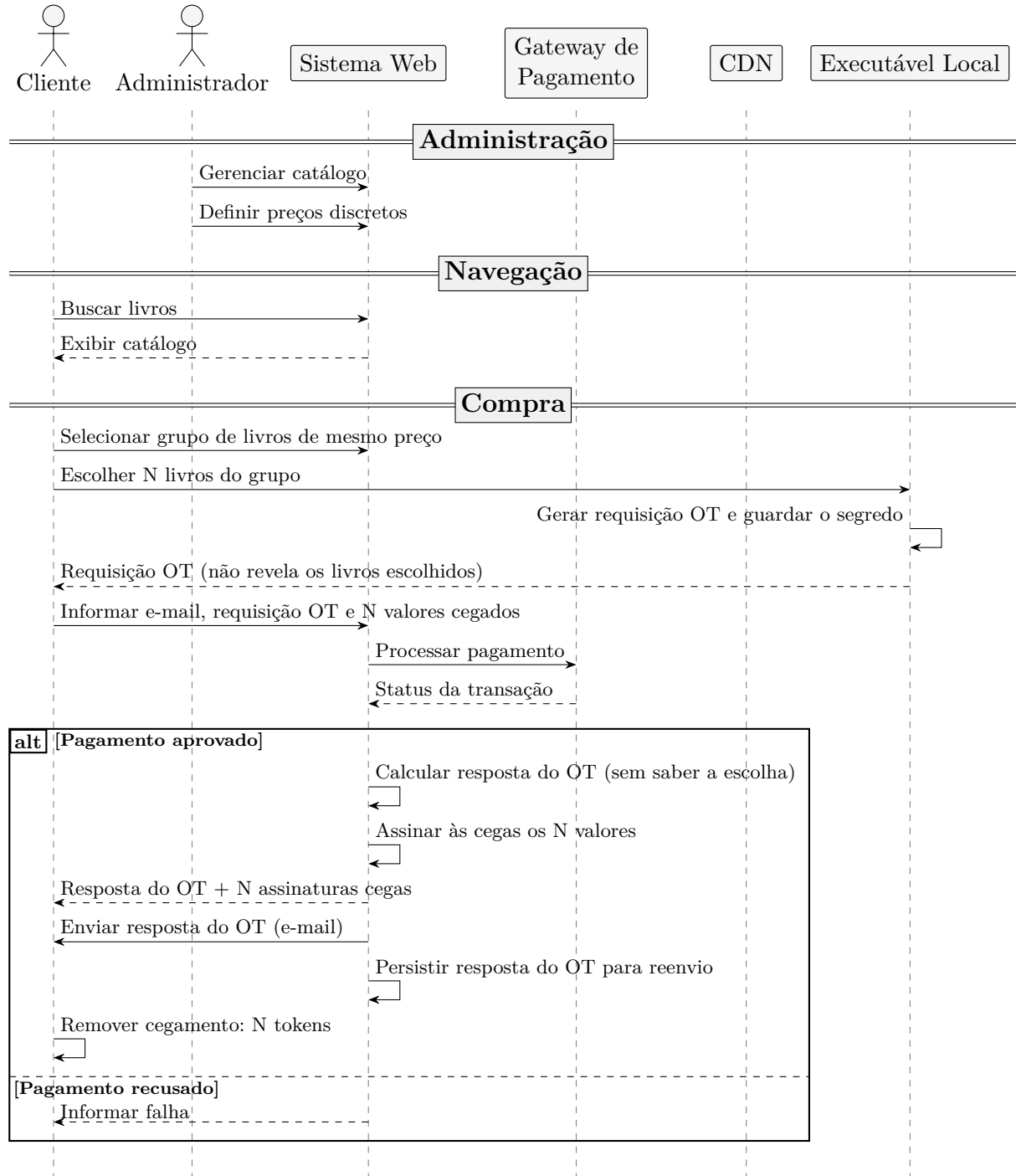
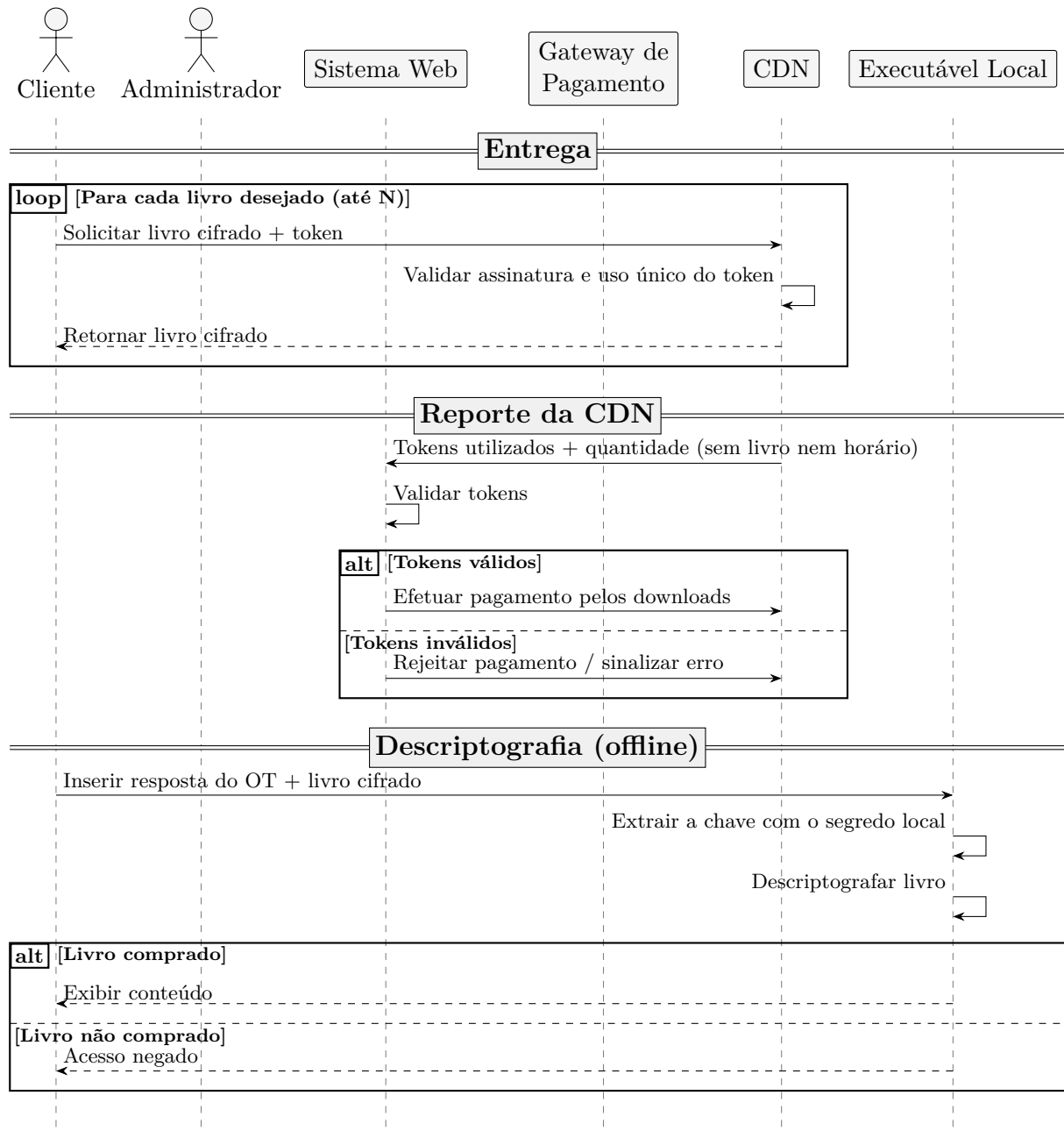


Figura 2 – Diagrama de sequência: entrega, reporte da CDN e descriptografia



## Referências

RABIN, M. O. How to exchange secrets with oblivious transfer. *Cryptology ePrint Archive, Report 2005/187*, 2005. Disponível em: <<https://eprint.iacr.org/2005/187.pdf>>. Citado 2 vezes nas páginas 9 e 11.

TASSA, T. Generalized oblivious transfer by secret sharing. *Designs, Codes and Cryptography*, 2011. Disponível em: <<https://www.openu.ac.il/home/tamirtassa/Publications/got.pdf>>. Citado 2 vezes nas páginas 7 e 11.